

Section 05

Industrial Security (Bachelor)



Section 05 – Threat Landscape

Threat Landscape

Lecture Notes

Department of Computer Science

1 Threat Actors and Frameworks

2 Landmark Incidents

3 Cross-Cutting Risks

By the end of this section you will be able to

- Categorise threat actors targeting industrial environments.
- Map ICS attacks to the MITRE ATT&CK for ICS matrix.
- Analyse landmark incidents: Stuxnet, Ukraine, TRITON, Colonial.
- Identify supply-chain and insider risk vectors.

1

Threat Actors and Frameworks

Section 05 – Threat Landscape

Nation-state APTs – Sandworm, Volt Typhoon, Lazarus

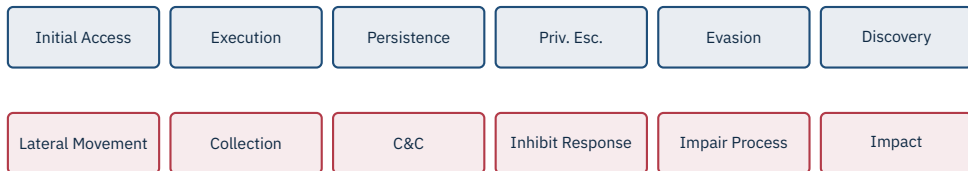
Cybercrime / Ransomware – LockBit, BlackCat, Conti

Hacktivists – CyberAv3ngers, GhostSec

Insiders – disgruntled employees, contractors

Opportunists – script kiddies, Shodan hunters

Competitors – industrial espionage



Why this matters

ATT&CK for ICS gives a shared vocabulary for techniques, detections, and incident discussion across teams and vendors.

2

Landmark Incidents

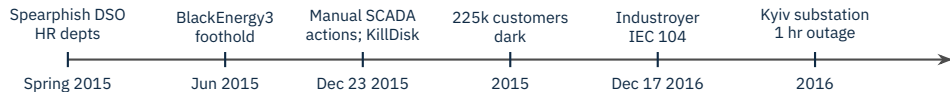
Section 05 – Threat Landscape



Natanz, 2010

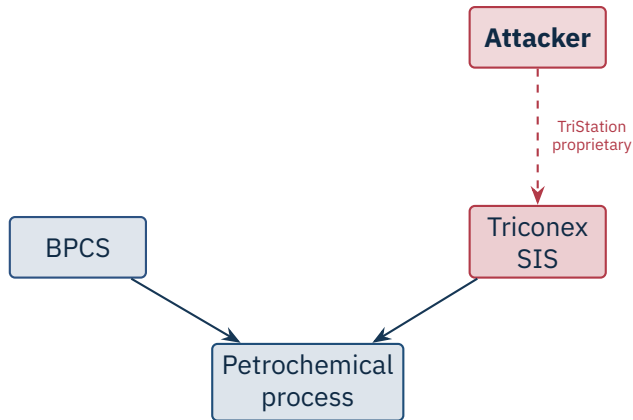
Four zero-days, two stolen code-signing certificates. Subtly destroyed an estimated ~1 000 centrifuges over months while feeding the HMI *normal-looking* data. The first widely-known cyber-physical weapon.

Source: N. Falliere, L. Murchu, E. Chien, *W32.Stuxnet Dossier v1.4*, Symantec, 2011 | D. Albright et al., *ISIS report*, 2010.



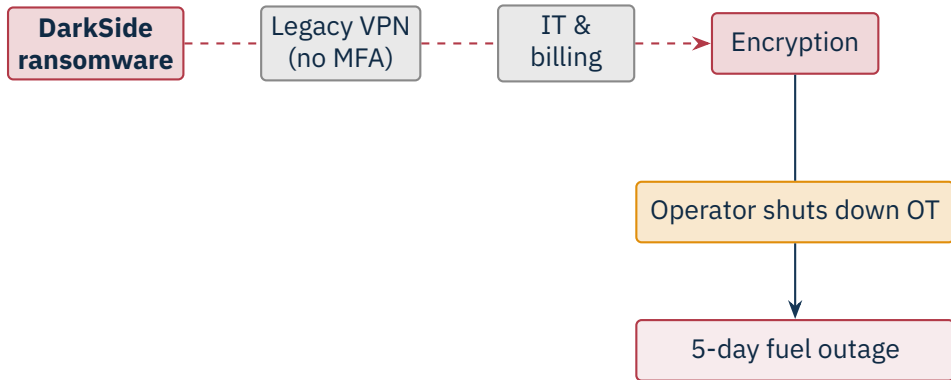
Sandworm (GRU). Industroyer was the first malware framework with built-in grid protocol modules.

Source: R. M. Lee, M. J. Assante, T. Conway, *Analysis of the Cyber Attack on the Ukrainian Power Grid*, SANS/E-ISAC, 2016 | A. Cherepanov, *Win32/Industroyer*, ESET, 2017.



First publicly known attack on a Safety Instrumented System. A programming error in the malware tripped the plant and exposed the operation. Watershed moment: attackers reached the safety layer.

Source: Dragos, TRISIS Malware Analysis, 2017 | Mandiant/FireEye, Attackers Deploy New ICS Attack Framework "TRITON", 2017.

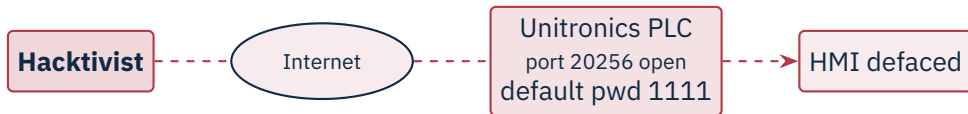


IT compromise; the operator pre-emptively halted OT. Highlights IT/OT interdependence and the physical impact of ransomware.

Source: FBI, Statement on Colonial Pipeline, May 2021 | GAO-22-104746, 2022.

Lessons that keep coming back

Default credentials and **direct Internet exposure** of PLCs are still common – and still get exploited by low-skill actors at scale.



No process damage, but trivially exploited at multiple water utilities. **Reminder:** never expose OT to the Internet, always change defaults.

Source: CISA AA23-335A, "IRGC-Affiliated Cyber Actors Exploit PLCs in Multiple Sectors", 1 Dec 2023.

3

Cross-Cutting Risks

Section 05 – Threat Landscape

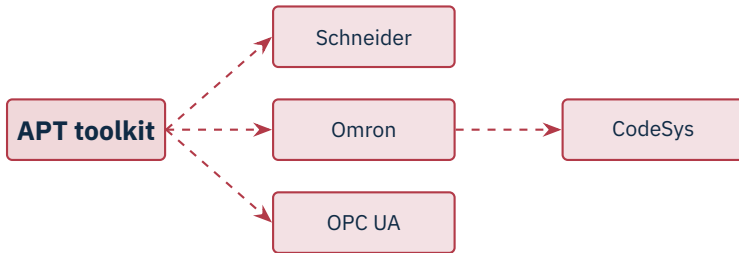


SolarWinds, 3CX, MOVEit – and OT-relevant cases such as Codesys runtime CVEs (*CoDe16*).



Maroochy Shire (2000): ex-contractor with a stolen radio modem released sewage 46 times.

Source: J. Slay & M. Miller, "Lessons learned from the Maroochy Water breach", *Critical Infrastructure Protection*, IFIP, 2008.



First multi-target ICS framework

PIPEDREAM is the first modular framework with pre-built modules for several vendors at once – captured before it was used in anger.

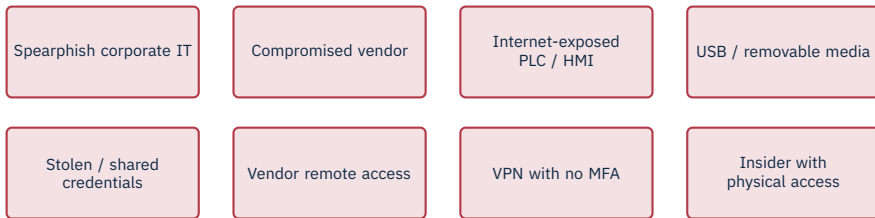
Source: CISA AA22-103A, "APT Cyber Tools Targeting ICS/SCADA Devices", 13 Apr 2022 | Dragos, *PIPEDREAM/CHERNOVITE* report, 2022 | Mandiant, *INCONTROLLER*, 2022.

- Suspected China-linked APT, active since at least 2021.
- Targets US critical infrastructure: telecoms, water, energy.
- Uses *built-in tools* (PowerShell, WMI, native Windows) – minimal new malware.
- Apparent goal: pre-positioning for disruptive action during conflict.

Caution

The hardest threat to detect is the one that looks like a normal admin task. Behavioural analytics matter more than signatures.

Source: CISA AA24-038A, “PRC State-Sponsored Actors Compromise and Maintain Persistent Access to U.S. Critical Infrastructure”, 7 Feb 2024 | Microsoft, Volt Typhoon, May 2023.



Source: Dragos Year in Review 2024 – initial access vectors observed across 23 OT-targeting groups.

★ Key Takeaway: What to remember from this section

- Threat actors range from script kiddies to nation-state APTs, each with different capabilities.
- MITRE ATT&CK for ICS provides a shared vocabulary for techniques and detections.
- Stuxnet → Ukraine → TRITON shows an escalating willingness to harm.
- Supply chain and insider risk demand controls beyond the perimeter.

- Falliere, N., Murchu, L., Chien, E. *W32.Stuxnet Dossier*, v1.4. Symantec, Feb 2011.
- Langner, R. *To Kill a Centrifuge*, The Langner Group, Nov 2013.
- Albright, D. et al. *Did Stuxnet take out 1,000 centrifuges at Natanz?* ISIS, 22 Dec 2010.
- Lee, R.M., Assante, M.J., Conway, T. *Analysis of the Cyber Attack on the Ukrainian Power Grid*, SANS/E-ISAC, 18 Mar 2016.
- Cherepanov, A. *Win32/Industroyer*, ESET, June 2017.
- Dragos. *TRISIS Malware Analysis*, Dec 2017.
- Mandiant/FireEye. *Attackers Deploy New ICS Attack Framework “TRITON”*, Dec 2017.
- FBI. *Statement on the Colonial Pipeline attack*, May 2021.
- GAO-22-104746. *Critical Infrastructure Protection: Federal Authorities – Colonial Pipeline Response*, 2022.
- CISA AA22-103A. “APT Cyber Tools Targeting ICS/SCADA Devices” (PIPEDREAM/INCONTROLLER), 13 Apr 2022.
- Mandiant. *INCONTROLLER: New State-Sponsored Cyber Attack Tools*, Apr 2022.
- Dragos. *PIPEDREAM/CHERNOVITE*, 2022.
- CISA AA23-335A. “IRGC-Affiliated Cyber Actors Exploit PLCs in Multiple Sectors”, 1 Dec 2023.
- CISA AA24-038A. “PRC State-Sponsored Actors Compromise and Maintain Persistent Access to U.S. Critical Infrastructure” (Volt Typhoon), 7 Feb 2024.

- Microsoft Threat Intelligence. *Volt Typhoon targets US critical infrastructure with living-off-the-land techniques*, May 2023.
- Slay, J., Miller, M. “Lessons learned from the Maroochy Water breach.” In *Critical Infrastructure Protection*, IFIP, 2008.
- MITRE. *ATT&CK for ICS*, knowledge base, <https://attack.mitre.org/matrices/ics/>.
- Dragos. *Year in Review*, annual reports.

End of Section 05



Threat Landscape

Questions and discussion